MODULE 11 · DOMAIN 3 - INTEGRATION

Capability Bloat and Least Privilege

Spotting bloat, auditing a tool set, designing tools that are hard to misuse, and least privilege enforced in code.

DOMAIN 3 of 7 EXAM WEIGHT 19% MODULE 11 of 38

admin@sthithapragna.com

Domain 3 at a glance

OBJECTIVE	MODULE
Capability bloat and least privilege	11
Progressive discovery versus monolithic context	12
Integration mechanism: MCP, API or CLI, agent-to-agent	13
RAG: chunking, indexing, retrieval matched to the data	14
Identity and authorisation gaps	15
Accuracy-latency trade-offs and observability at scale	16

ON THE EXAM

The heaviest domain. Nearly one item in five is about wiring Claude into real systems.

Every tool is a choice the model must get right, **and a door someone could open**.

What capability bloat looks like

- **Wrong tool, more often:** overlapping descriptions blur the choice.
- **Slower and dearer:** every definition is sent, and read, on every request.
- **Bigger blast radius:** a confused or manipulated agent can reach more.
- **Anthropic's test:** if a human engineer cannot say which tool fits, the agent cannot either.

> ON THE EXAM
>
> Bloat is a quality problem and a security problem with the same cause.

The tool audit: keep, merge, remove

- **Keep** tools for defined tasks, and routine hand-offs such as escalation to a person.
- **Merge** tools that overlap, or that are always called together.
- **Remove** tools that no defined task needs.
- **Usage counts inform the audit; they do not decide it.** A rare hand-off still stays.

> ON THE EXAM
>
> The question is never how often a tool is used. It is whether a defined task needs it.

Consolidate, rather than wrap every endpoint

ONE TOOL PER ENDPOINT

Five tools, one job

```
list_engineers
get_engineer_calendar
find_free_slots
create_booking
send_confirmation
```

Five choices, five chances to pick wrong, five definitions per request.

ONE TOOL PER TASK

Built around the workflow

```
scheduling_book_visit
  customer_id
  site_id
  earliest_date
  latest_date
finds a free engineer,
books, and confirms
```

Fewer, more capable tools reduce selection ambiguity.

THE TIEBREAKER

Anthropic: build a few tools around high-impact workflows, not one per API endpoint.

Designing tools the model can't misuse

PRACTICE	WHAT IT LOOKS LIKE
Describe fully	Three or four sentences: what, when, when not, limits
Name parameters clearly	customer_id, not user
Namespace by service	billing_search, helpcentre_search
Mistake-proof the inputs	Enums, absolute paths, required fields
Return high-signal results	Names and slugs, not raw internal IDs
Make errors actionable	What was wrong, and how to retry

ON THE EXAM

Anthropic calls the description by far the most important factor in tool performance.

From bloated to focused

01
Inventory
Each tool, the task it serves, its usage.

02
Remove
Tools no defined task needs.

03
Consolidate
Overlaps become workflow tools.

04
Split by domain
One focused agent per domain.

05
Route, re-test
Then add routing. Rerun the evals.

ON THE EXAM

Routing comes last. A router in front of a bloated agent hides the problem.

Least privilege for agents

- **Each agent** gets only the tools its defined tasks need.
- **Each tool** gets only the access its task needs: read-only where reads suffice.
- **Enforced outside the model:** the orchestrator and the tool service decide.
- **Assume the model can be confused or manipulated.** Design for that day.

> THE PICTURE
>
> A hotel keycard opens your floor and nothing else. Give every agent a keycard, not a master key.

Remove it, or just watch it?

CONTROLS THAT PREVENT

Shrink what is possible

- Remove the tool from this agent
- Scope the credential to the task
- Allow-list per role, outside the model
- Server checks authorisation on every call
- Read-only versions where reads suffice

CONTROLS THAT ONLY OBSERVE OR ASK

The door stays open

- Logging and alerts
- Asking the model to confirm first
- A prompt rule: never use this tool
- Reviewing calls after the fact
- A more capable model

THE TIEBREAKER

Logging a dangerous tool is CCTV on an unlocked door. Useful, but it is not a lock.

Where least privilege is enforced

Orchestrator

Sends only the role's tools
Leaves the rest out

Credentials

Scoped per role and task
No shared admin key

Per-role allow-list

Set from the signed-in identity
Checked on every call

Decided by code, not the model

Tool service

Re-checks authorisation
Validates every input

System prompt

Explains the boundaries
Never the enforcement

THE TAKEAWAY

The prompt explains the rules; code enforces them. A model cannot misuse a tool it was never given.

Least privilege in today's stack

WHERE	WHAT ACTUALLY RESTRICTS
Messages API	Only the tools you send exist for that request
Agent SDK	disallowedTools by name removes a tool; allowedTools only pre-approves
Agent SDK, headless	allowedTools plus dontAsk mode: everything else is denied
MCP, 2026-07-28 spec	tools/list may vary with the caller's authorisation
MCP tool annotations	Read-only and destructive hints are untrusted from unknown servers

ON THE EXAM

An allow-list that only pre-approves is not a restriction. Check what each control really does.

> Tallyhawk's support agent launched with 9 tools. After 18 months of additions it has 41, several with overlapping descriptions across billing, scheduling and account admin.
>
> First-contact resolution has fallen from 84% to 71%, and tool selection has slowed. A product lead proposes putting a router agent in front.

What should Corvane recommend first?

A Put a router agent in front of the existing agent, as proposed

B Move the agent to the most capable model tier

C Add a rule to the system prompt for when to use each tool

D Prune and merge overlapping tools, then split them into domain agents

◆ PAUSE AND DECIDE

What should Corvane recommend first?

A. Put a router agent in front of the existing agent, as proposed

Adds a model call, with the same 41 overlapping tools behind it.

B. Move the agent to the most capable model tier

A stronger model still faces ambiguous choices, at a higher cost.

C. Add a rule to the system prompt for when to use each tool

More tokens to explain tools that should not overlap at all.

D. Prune and merge overlapping tools, then split them into domain agents

Removes the ambiguity, then gives a router something clean to route to.

THE SIGNAL

Overlapping tools across separable domains: decompose before you route.

> Quillon's patient-portal assistant books and moves appointments, explains bills and gives directions. It was assembled from a shared tool library and can call 14 tools.
>
> A security review finds it can also issue refunds and edit insurance records, which none of its tasks need. Its tool for escalating to the portal team is used in under 1 conversation in 100.

What should Corvane recommend?

A. Keep the tools, and alert security whenever one is called

B. Remove the tools its tasks do not need, keeping escalation

C. Remove every tool used in under one conversation in a hundred

D. Require the patient to confirm before any refund or record edit

◆ PAUSE AND DECIDE

What should Corvane recommend?

A. Keep the tools, and alert security whenever one is called

Watches the door instead of locking it. The harm comes before the alert.

B. Remove the tools its tasks do not need, keeping escalation

Least privilege by task. Escalation is a routine hand-off, so it stays.

C. Remove every tool used in under one conversation in a hundred

Usage is the wrong test. This also removes the hand-off to staff.

D. Require the patient to confirm before any refund or record edit

A manipulated conversation can produce a confirmation. The capability remains.

THE SIGNAL

Unneeded dangerous tools: remove them. Keep what defined tasks and hand-offs need.

> Tallyhawk's support agent serves two kinds of user. Account administrators may change user roles and billing details. Ordinary users may only view schedules and raise tickets.
>
> Today every request gets all the tools, and the system prompt says to use admin tools only for administrators.

How should Corvane enforce the difference?

A Select the tool set from the signed-in user's role in code, and re-check the role on every call

B Have the agent ask users whether they are administrators before admin actions

C Keep the prompt rule, and flag admin tool calls for review each week

D Put the user's role into the system prompt so the model can decide reliably

◆ PAUSE AND DECIDE

How should Corvane enforce the difference?

A Select the tool set from the signed-in user's role in code, and re-check the role on every call

The model never sees tools the role lacks, and the service refuses anyway.

B Have the agent ask users whether they are administrators before admin actions

Users can claim anything. Identity comes from sign-in, not conversation.

C Keep the prompt rule, and flag admin tool calls for review each week

Finds misuse a week after the damage.

D Put the user's role into the system prompt so the model can decide reliably

Better information, same enforcer. A model can be talked round.

THE SIGNAL

Who may do what is decided by code from the signed-in identity, never by the model.

> Tallyhawk's support agent connects to two MCP servers, one for the help centre and one for billing. Each server exposes a tool named search, with a one-line description.
>
> When customers ask about invoices, the agent often searches the help centre and answers with generic articles.

Which change most directly fixes this?

A. Add examples of invoice questions to the system prompt

B. Disconnect the help-centre server during billing conversations

C. Prefix each tool with its service, and describe what it searches and when to use it

D. Raise the effort level so the agent reasons more about tool choice

◆ PAUSE AND DECIDE

Which change most directly fixes this?

A Add examples of invoice questions to the system prompt

Helps a little, but the two tools still look identical.

B Disconnect the help-centre server during billing conversations

Needs the topic before the agent knows it, and breaks mixed questions.

C Prefix each tool with its service, and describe what it searches and when to use it

Names and descriptions are what the model selects on. Make them distinct.

D Raise the effort level so the agent reasons more about tool choice

More reasoning over identical descriptions is still a guess.

THE SIGNAL

Two tools that look the same: fix the names and descriptions first.

> Corvane is building a headless overnight agent with the Agent SDK for Mereside's mortgage document packs. It must read the packs and write extraction files, and must never run shell commands.
>
> An engineer set allowedTools to Read and Write, and chose bypassPermissions mode so that nothing stalls overnight.

What should Corvane change?

A Nothing, because the allow-list already limits the agent to Read and Write

B Add a system prompt rule that forbids shell commands

C Keep bypass mode, and log every shell command for morning review

D Remove Bash by name with disallowedTools, and run in dontAsk mode

◆ PAUSE AND DECIDE

What should Corvane change?

A Nothing, because the allow-list already limits the agent to Read and Write

The list only pre-approves. Bypass mode approves the unlisted tools too.

B Add a system prompt rule that forbids shell commands

A prompt is not a control. Bash is still in the request.

C Keep bypass mode, and log every shell command for morning review

Records the damage after it happens.

D Remove Bash by name with disallowedTools, and run in dontAsk mode

Bash leaves the request; any other unapproved call is denied, not prompted.

THE SIGNAL

Check what a control actually does. An allow-list that only pre-approves restricts nothing.

> Brackenway Logistics' procurement agent checks stock and drafts purchase orders for a buyer to approve. The ERP system's MCP server gives it about 60 tools.
>
> They include creating suppliers and approving payments. The agent signs in with an admin service account.

Which two changes most directly limit what a misled agent can do? Choose two.

A. List in the system prompt the tools it must never call

B. Send every tool call to the security monitoring system

C. Move to a more capable model that follows instructions better

D. Expose only the stock and draft-order tools to this agent

E. Replace the admin account with a credential scoped to stock reads and drafts

◆ PAUSE AND DECIDE

Which two changes most directly limit what a misled agent can do? Choose two.

A List in the system prompt the tools it must never call

Words, not a barrier. The tools still exist.

B Send every tool call to the security monitoring system

Detects misuse. Does not prevent it.

C Move to a more capable model that follows instructions better

Better on average; the capability and the admin account remain.

D Expose only the stock and draft-order tools to this agent

The agent cannot call what it is never offered.

E Replace the admin account with a credential scoped to stock reads and drafts

Even a call that slips through cannot exceed the credential.

THE SIGNAL

Least privilege works in layers: fewer tools offered, narrower rights behind them.

In five lines

- **Bloat costs accuracy, tokens and safety.** If an engineer can't pick the tool, nor can Claude.
- **Audit by task, not usage:** keep tasks and hand-offs, merge overlaps, remove the rest.
- **Hard to misuse:** full descriptions, clear names, namespaces, mistake-proof inputs.
- **Least privilege:** remove, scope, enforce in code. Logs and prompts are not locks.
- **Split by domain before you route.**

COMING UP

Next: progressive discovery versus monolithic context.